

PENETRATION TESTING REPORT

Mediroza General Hospital

Web Application Security Assessment

Pentester Name	Collins Okike
Batch	B083-Networkwalks
Date	30th September 2026
Target	https://medirozahospital.com/
Assessment Type	Full black-box penetration test

Executive Summary

The security assessment of Mediroza General Hospital was conducted as a black-box penetration test against the hospital's web infrastructure. The assessment focused on identifying weaknesses that could allow unauthorized access to restricted areas, exposure of confidential patient information, recovery of protected files, and access to sensitive hospital data. The testing was conducted within the authorized scope provided for the engagement.

The assessment identified multiple weaknesses across the hospital's web application and exposed resources. During testing, directory enumeration revealed accessible areas including /staff/, /patient/, and /old/. Testing of the staff login did not result in a successful SQL injection or authentication bypass; however, applying the same input-testing approach to the patient portal resulted in successful access to the restricted patient area. This provided access to three encrypted patient PDF laboratory reports.

The recovered PDF files were subsequently processed to extract crackable hashes. An initial attempt with John the Ripper did not produce a result, after which the NetworkWalks Hash Calculator was used to generate crackable hashes. The hashes were then tested with the NetworkWalks Password Cracker using multiple wordlists, resulting in recovery of the passwords required to open the protected files.

Further investigation of the directories identified during reconnaissance led to the /old/ directory, where a database backup file, mediroza_db_backup_2019.sql, was directly accessible. Analysis of the exposed database provided access to sensitive information relating to hospital employee salaries and shareholder details.

- Unauthorized Access: Weaknesses in the patient portal authentication process allowed access to a restricted area of the application.
- Patient Data Exposure: Access to the patient portal exposed confidential laboratory reports belonging to patients.
- Sensitive File Exposure: The protected PDF files could be processed and their passwords recovered through password-cracking techniques.
- Database Exposure: The publicly accessible database backup exposed sensitive organizational information, including employee salary and shareholder details.

Mediroza General Hospital can reduce the risks identified during the assessment by strengthening authentication and input validation, preventing directory indexing and direct access to backup files, removing sensitive files from publicly accessible locations, and applying stronger password protection to sensitive documents. Regular security testing and appropriate controls around exposed web resources should also be maintained to reduce the likelihood of similar exposures occurring again.

Scope and Methodology

The assessment was conducted as a full black-box penetration test against the Mediroza General Hospital web infrastructure. The target was:

- Target: <https://medirozahospital.com>
- IP Address: 199.188.201.16

The assessment followed the project milestones, starting with reconnaissance and directory enumeration, followed by authentication and user-input testing, retrieval and password recovery of the three patient PDF reports, and investigation of the exposed database backup.

The main tools and resources used during the assessment were:

- Nikto v2.6.1 — reconnaissance and directory enumeration.
- John the Ripper — initial attempt to recover the PDF passwords.
- NetworkWalks Hash Calculator — extraction of crackable PDF hashes.
- NetworkWalks Password Cracker — password recovery using multiple wordlists.

Testing was limited to the authorized target domain. No social engineering, denial-of-service testing, or testing outside the agreed scope was performed. The staff login SQL injection attempts did not provide a successful bypass, and the initial John the Ripper attempt did not produce a result. These limitations led to testing the other exposed entry points and using the alternative password-recovery method.

Findings and Proof of Exploitation

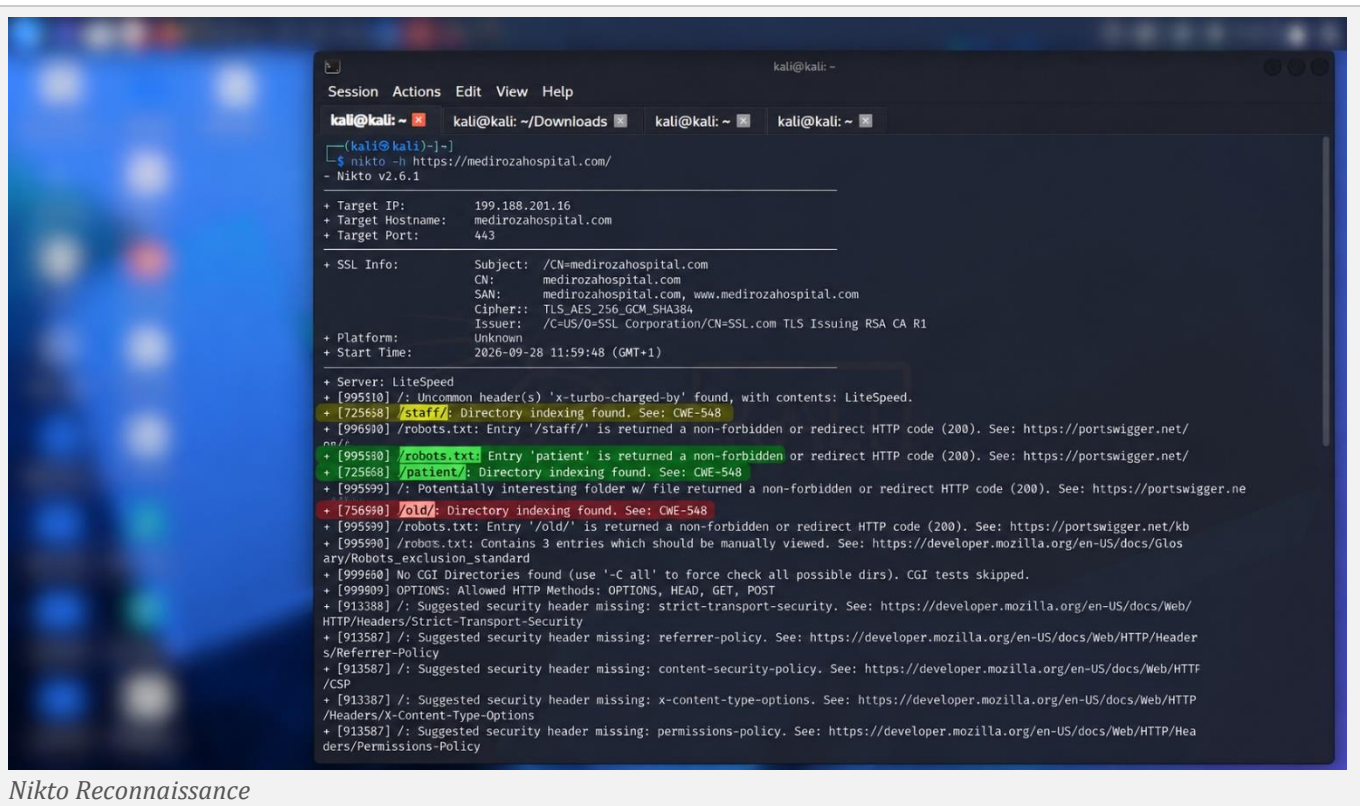
The following findings were identified during the assessment. Each finding is supported by the corresponding evidence collected during the engagement.

Finding 01 — Exposed Directories

During reconnaissance, I used Nikto v2.6.1 against <https://medirozahospital.com/>. The scan identified the following directories:

- /staff/
- /patient/
- /old/

Nikto also reported directory indexing on these locations. These exposed directories provided entry points for further investigation.



Finding 02 — Patient Portal Authentication/Input Handling

I investigated the Staff Login first at: <https://medirozahospital.com/staff/login.php>

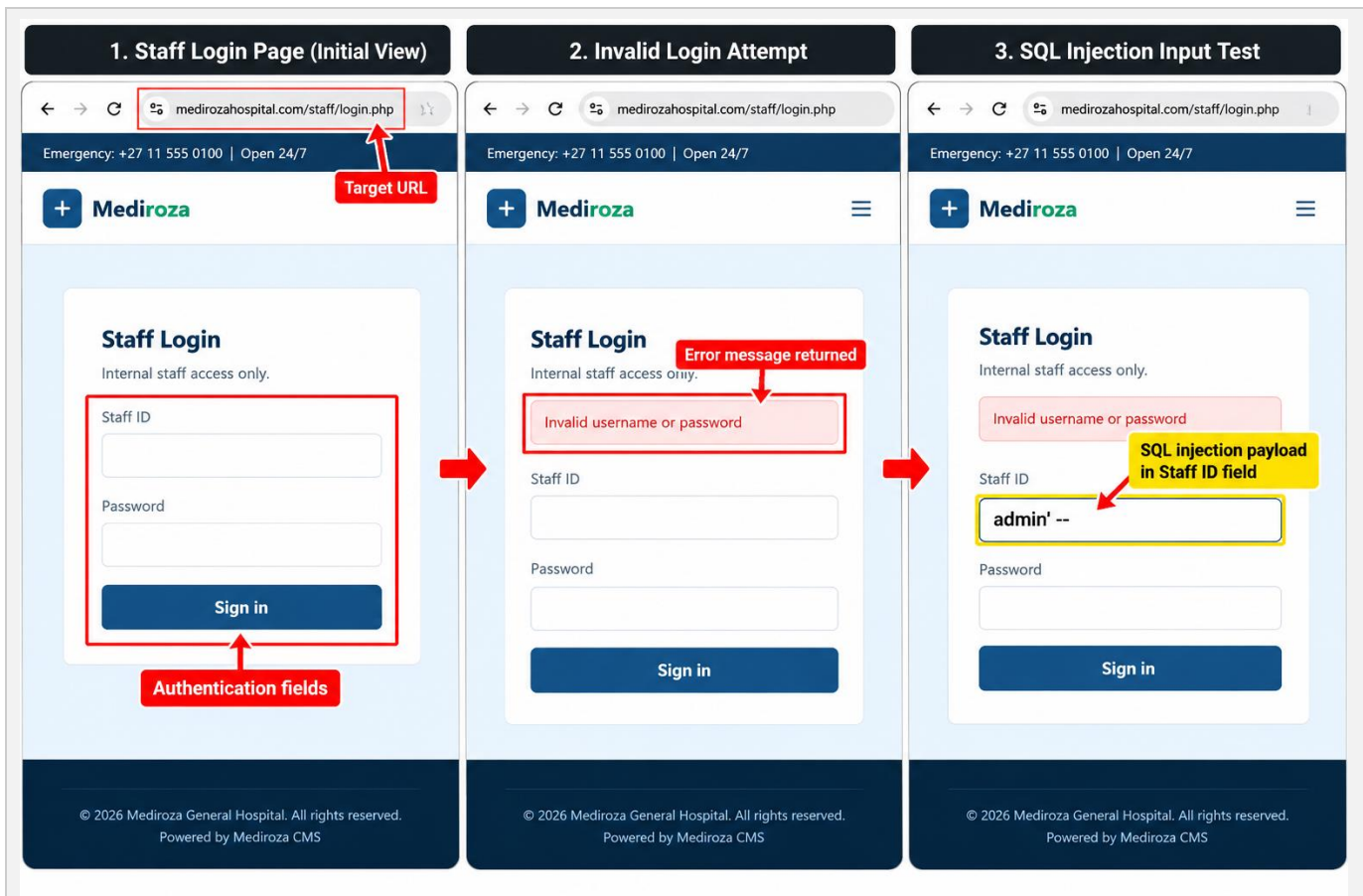
I made multiple authentication attempts and tested the Staff ID field for SQL injection. The attempts did not produce a successful bypass and the application returned “Invalid username or password.”

I then tested the Patient Portal at: <https://medirozahospital.com/patient/login.php>

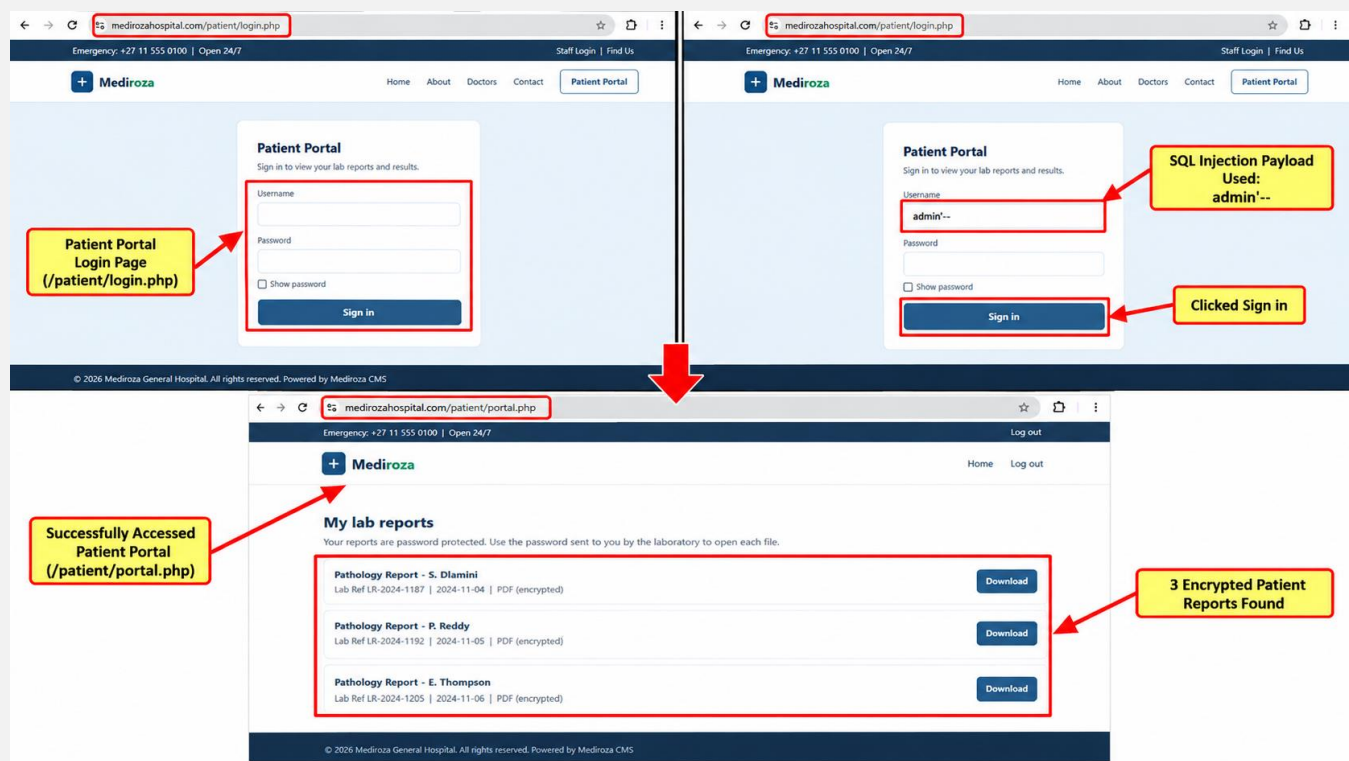
Using the same input-testing approach, I was able to gain access to:

<https://medirozahospital.com/patient/portal.php>

The portal contained three password-protected patient laboratory reports.



Staff Login, Authentication & SQL Injection Testing



Patient Portal SQL Injection & Access

Finding 03 — Protected PDF Password Recovery

After gaining access to the patient portal, I downloaded the three encrypted PDF reports.

I first attempted to recover the passwords using John the Ripper, but this did not produce a result. I then used the NetworkWalks Hash Calculator to extract crackable hashes from the three encrypted PDFs. The hashes were then processed using the NetworkWalks Password Cracker with multiple wordlists.

The passwords recovered were:

Patient Report	Recovered Password
Patient Report 1	123456
Patient Report 2	password
Patient Report 3	!@#%&^&

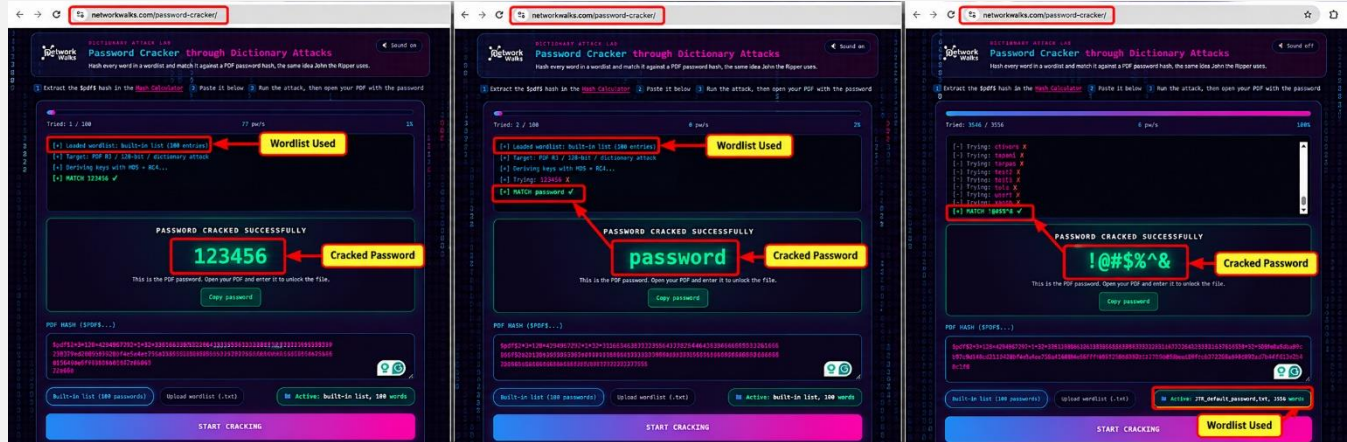
This allowed the protected PDF files to be opened.

The image displays three side-by-side screenshots of the NetworkWalks Hash Calculator web application. Each screenshot shows the tool's interface with a dark blue header and a light blue body. The tool is used to extract crackable hashes from password-protected PDF files. In each screenshot, a specific PDF file is uploaded, and the resulting hash is displayed in a red box. A yellow callout box points to the hash, indicating it has been extracted from the respective PDF report.

- Left Screenshot:** The file 'patient_report_1.pdf' (3.6 KB) is uploaded. The extracted hash is: `$pdf$2*3*128*429496729*1*32*336166336522254433335537632383812383736335339*32*4736c3a0d6f0e3c18c79b6d28895c5928b746e4de758a635884c454f4f9288c56f7251c3440d30740f71ac5a72b10182d446e7122f1a69d6`. The callout box says: "Extracted hash from patient_report_1.pdf".
- Middle Screenshot:** The file 'patient_report_2.pdf' (3.6 KB) is uploaded. The extracted hash is: `$pdf$2*3*128*429496729*1*32*316544383372236556437624464363834664632263163313323861832777864a0b0d0f12444c54ef999995520bf4ef0e475845164094c6ffffa030*32*4303070c12a733772840f3c1b917822377551d464c314ad18a0d5555551`. The callout box says: "Extracted hash from patient_report_2.pdf".
- Right Screenshot:** The file 'patient_report_3.pdf' (3.6 KB) is uploaded. The extracted hash is: `$pdf$2*3*128*429496729*1*32*327613966632138833645486337723633863437324233833676154538*32*5999f4ba5d9a99c997c9d148cc33119428b74c5e4e728c5164094c6ffffa030*32*38e4660215705b401a528fcd7534f955a2b4dc178`. The callout box says: "Extracted hash from patient_report_3.pdf".

Each screenshot also shows the tool's status: "This PDF is encrypted. A crackable hash has been extracted below (pdf2john / hashcat compatible format)." and "Revision: R3 Version: V2 Key length: 128 bit".

Patient PDF Hash Extraction



Patient PDF Password Cracking

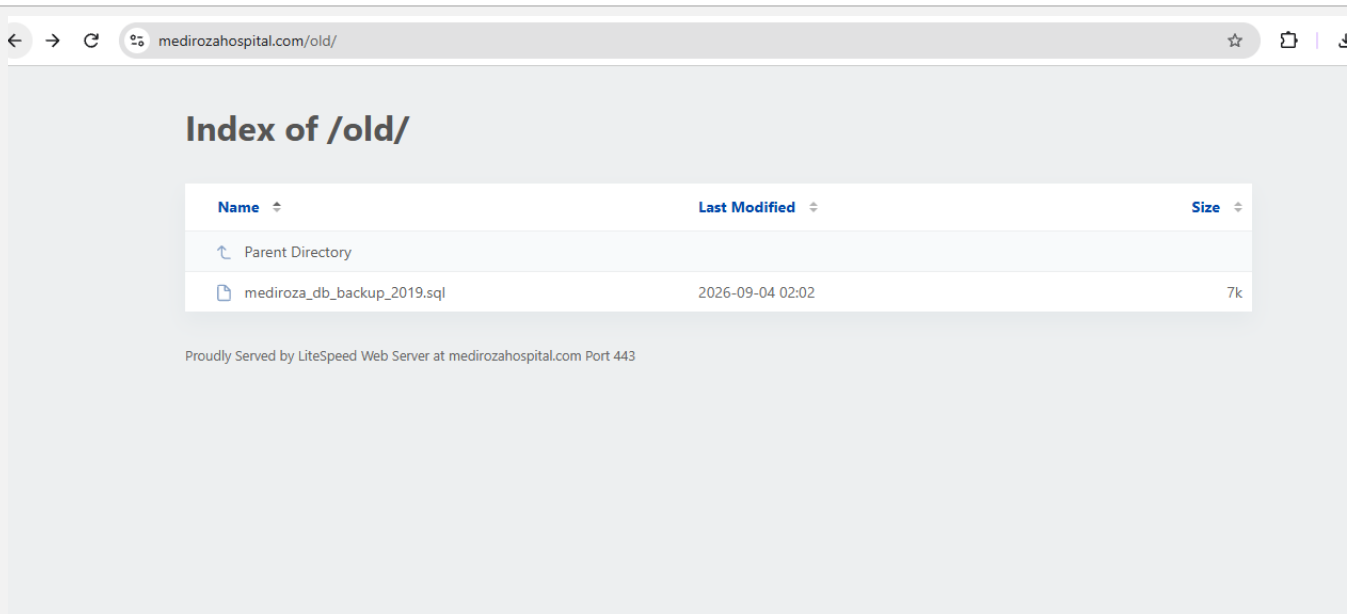
Finding 04 — Exposed Database Backup

After completing the earlier stages, I reviewed the directories identified during reconnaissance again.

The /old/ directory contained an exposed database backup: mediroza_db_backup_2019.sql

The database backup was directly accessible through the web directory.

I extracted information from the database required for the M3 assessment, including employee salaries and shareholder details.



Exposed Database Backup

Staff Salary Information

The exposed database contained the monthly salary information for hospital employees.

Salaries are monthly figures in South African Rand (ZAR).

ID	Full Name	Job Title	Department	Salary (ZAR)
1	Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	R 138,000
2	Sarah Botha	Chief Financial Officer	Finance	R 152,000
3	Dr. Johan van der Merwe	Medical Director	Management	R 160,000
4	Dr. Anita Naicker	Consultant Cardiologist	Cardiology	R 132,000
5	Dr. Ahmed Kara	Consultant Physician	Internal Medicine	R 128,000
6	Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	R 74,000
7	Michael Roberts	HR Director	Human Resources	R 96,000
8	Susan Pretorius	HR Officer	Human Resources	R 32,000
9	Jameel Malik	IT Systems Administrator	IT	R 58,000
10	Thabo Molefe	Network Engineer	IT	R 46,000
11	Nomvula Khumalo	Registered Nurse	Emergency & Trauma	R 34,000
12	Lerato Mokoena	Registered Nurse	Pediatrics	R 33,000
13	Bongani Ndlovu	Registered Nurse	Cardiology	R 35,000
14	Zanele Mahlangu	Nursing Sister	Theatre	R 42,000
15	Kagiso Sithole	Pharmacist	Pharmacy	R 61,000
16	Naledi Zulu	Pharmacy Assistant	Pharmacy	R 26,000
17	Themba Nkosi	Radiographer	Radiology	R 44,000
18	Palesa Radebe	Radiographer	Radiology	R 43,000
19	Deepak Pillay	Lab Technologist	Diagnostics Lab	R 41,000
20	Kavitha Govender	Lab Technician	Diagnostics Lab	R 35,000
21	Dr. Suresh Moodley	Consultant Radiologist	Radiology	R 130,000
22	Dr. Fatima Patel	Pediatrician	Pediatrics	R 118,000
23	Nisha Singh	Physiotherapist	Rehabilitation	R 48,000
24	Dr. Vikram Chetty	Anaesthetist	Theatre	R 135,000
25	David Smith	Facilities Manager	Operations	R 52,000
26	Karen O'Connor	Billing Administrator	Finance	R 29,000
27	James Wilson	Security Supervisor	Operations	R 27,000
28	Linda Fourie	Receptionist	Front Office	R 19,000
29	Peter van Wyk	Procurement Officer	Supply Chain	R 38,000
30	Andile Mbeki	Ward Clerk	Administration	R 21,000

Shareholder Information

The exposed database also contained the shareholder information required by the assessment.

Shareholder Details (10 shareholders — 1,000,000 shares)

ID	Shareholder Name	Share %	Shares Held	Share Class
1	Dr. Rajesh Naidoo	18.0%	180,000	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15.0%	150,000	Ordinary
3	Dr. Johan van der Merwe	12.0%	120,000	Ordinary
4	Reddy Family Trust	11.0%	110,000	Ordinary
5	Thabo Molefe	10.0%	100,000	Ordinary
6	Sarah Botha	9.0%	90,000	Ordinary
7	Dr. Ahmed Kara	8.0%	80,000	Preferential
8	Naledi Zulu	7.0%	70,000	Ordinary
9	Michael Roberts	6.0%	60,000	Ordinary
10	Dr. Vikram Chetty	4.0%	40,000	Preferential

Risk Assessment

Vulnerability Name	Risk Rating	Explanation
Exposed Directory Indexing	Medium	The /staff/, /patient/, and /old/ directories were accessible and directory indexing exposed useful information about the web application.
Patient Portal Authentication / Input Handling Weakness	Critical	Testing the Patient Portal resulted in access to the restricted patient area and exposed three confidential patient laboratory reports.
Weak Protection of Encrypted Patient PDF Files	High	The three PDF files were encrypted, but crackable hashes were extracted and the passwords were recovered using password-cracking techniques and multiple wordlists.
Exposed Database Backup	Critical	The /old/ directory exposed mediroza_db_backup_2019.sql, which contained sensitive employee salary and shareholder information.

Recommendations and Remediation

Based on the findings identified during the assessment, I recommend that Mediroza General Hospital implement the following remediation measures to reduce the security risks identified.

1. Exposed Directory Indexing

Directory indexing should be disabled on the web server so that visitors cannot browse the contents of directories such as /staff/, /patient/, and /old/.

The hospital should also review all publicly accessible directories and remove any files that are not required to be accessible through the web application. This will reduce the amount of information available to someone performing reconnaissance against the system.

2. Patient Portal Authentication and Input Handling

The Patient Portal authentication mechanism should be reviewed and strengthened to prevent unauthorized access through manipulated user input.

All user-supplied input should be properly validated on the server side, and database queries should use parameterized statements rather than directly incorporating user input. Authentication controls should also be tested to ensure that crafted input cannot be used to bypass the normal login process.

3. Protection of Patient PDF Reports

The password protection applied to the patient PDF reports should be strengthened. The passwords used to protect sensitive documents should be strong, unique, and difficult to recover through dictionary-based attacks.

Access to the reports should also be controlled through the application so that obtaining the files does not automatically provide an opportunity to attack their passwords offline.

4. Exposed Database Backup

The mediroza_db_backup_2019.sql file should be removed from the publicly accessible /old/ directory immediately.

Database backups should be stored in a location that is not accessible through the web server, with appropriate access controls applied. The web server should also be reviewed for other exposed backup files, old files, configuration files, and similar resources that could disclose sensitive information.

5. Ongoing Security Testing

Mediroza General Hospital should conduct regular vulnerability assessments and penetration tests against its web infrastructure. The exposed directories, authentication mechanisms, sensitive files, and backup locations should be included in future security reviews to ensure that previously identified weaknesses do not reappear.

Conclusion

The penetration testing assessment demonstrated that Mediroza General Hospital's web infrastructure has several security weaknesses that could result in unauthorized access and exposure of confidential information if left unresolved. The assessment showed that weaknesses in web application access controls, protection of sensitive files, and exposure of a database backup could allow an attacker to gain access to patient and organizational information.

Addressing the identified vulnerabilities and implementing the recommended remediation measures will help Mediroza General Hospital strengthen the security of its web infrastructure, protect sensitive patient and business information, and reduce the likelihood of similar security issues occurring in the future.